Protection Needs Elicitation & CIA Mapping

CASEVAULT | Secure Incident Evidence Exchange

CYC386 — Secure Software Design and Development / Fall 2026 Midterm Lab

Document control	Value
File	PNE_Report.md / PNE_Report.docx / PNE_Report.pdf
Version and status	1.0 — design baseline, pending real team validation
Team / members	[Enter real team name and up to three members]
Actual preparation date	[Enter actual date]
Instructor approval	[Record actual approval; not asserted]
Exam alignment	Teacher Sections 4 (Day 0–1), 5, 6.2; PNE/CIA rubric: 12 marks

DESIGN vs. EVIDENCE | The requirements below are proposed and testable, but are not represented as implemented, approved, independently interviewed, or verified.

1. Purpose and system boundary

CaseVault is the File Sharing / Collaboration case for confidential cybersecurity incident artifacts. Authenticated investigators upload bounded-size dummy files, grant/revoke named collaborators, download after object authorization, inspect SHA-256 references and see core audit events. The baseline is FastAPI/Jinja2 + SQLite + private file store + C metadata helper + Docker + GitHub/Jira. The file must stay private even when someone knows its ID.

MVP scope: authentication, file upload/list/download/delete, owner-controlled sharing, checksum, audit actions, native helper, five mandatory security controls, health and automated tests. Out of scope: malware detonation, public links, enterprise SSO, distributed storage, legal chain-of-custody guarantees, regulatory compliance. Local demo uses synthetic evidence on localhost; internet hosting needs additional controls.

2. Elicitation approach and stakeholder perspectives

These are scenario-derived proposed needs grounded in the exam and Phase 1 design. No genuine client interview has been provided. The team must validate constraints and document actual decisions in TEAM_VALIDATION.md.

ID	Stakeholder	Role / protection interest
ST-01	Evidence owner / investigator	Uploads an incident artifact, shares with named coworkers, revokes access, deletes own artifact. Confidentiality, authorized changes, availability; must not disclose by manipulating IDs.
ST-02	Authorized collaborator / analyst	Views and downloads evidence explicitly shared with their account. Read only within a current grant; must not inherit owner privileges.
ST-03	System administrator / security manager	Configures users and policies and reviews security posture; no admin evidence-browser capability in the MVP. Least privilege and controls over security events; no assumed unrestricted evidence access.
ST-04	Operator / DevSecOps engineer	Deploys app, maintains secrets, observes health, handles failures and CI/CD. Availability, bounded resource use, protected secrets, repeatable security gates.
ST-05	Adversary (abuse-case perspective)	Attempts unauthorized object access, forged

ID	Stakeholder	Role / protection interest
		state changes, unsafe metadata, or resource exhaustion. NOT an authorized product role. Negative test scenarios and design constraints; no approval or genuine interviews implied.
ST-06	Reviewer / instructor	Checks CIA rationale, code changes, tests, Git/Jira traceability and residual risks. Reproducible evidence and clear distinction between design and verified implementation.

2.1 Scenarios used to elicit the needs

Scenario	Business/abuse situation	PNE mapping
SC-01	Owner uploads an incident log and expects it to remain unreadable to other users.	PNE-001, PNE-010, PNE-011, PNE-012, PNE-015
SC-02	Owner grants a colleague access and later revokes it.	PNE-002, PNE-003, PNE-007, PNE-008
SC-03	Another authenticated user guesses an evidence identifier and tries to download/delete it.	PNE-001, PNE-004, PNE-011
SC-04	Malicious file metadata reaches a native parser or shell-like command path.	PNE-012, PNE-013, PNE-014, PNE-020
SC-05	User accesses sensitive actions from an external webpage or embedded frame.	PNE-008, PNE-009
SC-06	Investigator asks whether the downloaded evidence bytes still match the upload.	PNE-016, PNE-017
SC-07	Operator must reproduce tests and reject a high/critical finding before merge.	PNE-021, PNE-022, PNE-023
SC-08	Host disk is low or the service stops unexpectedly.	PNE-012, PNE-024, PNE-027
SC-09	System is considered for external production hosting after the lab.	PNE-025, PNE-026, PNE-027, PNE-028, PNE-029, PNE-030

3. Asset inventory

The exam requires inclusion of data, processes, components and external entities. The CIA columns below express primary sensitivities; the need-to-CIA mappings in Section 4 are authoritative.

Asset ID	Asset and category	Location	CIA
A-01	User identities and password hashes (Data)	FastAPI + SQLite	C/I
A-02	Authenticated session and anti-CSRF tokens (Data)	Browser / server session store	C/I
A-03	Incident evidence file contents (Data)	Private filesystem	C/I/A
A-04	Evidence metadata (owner, opaque ID, name, timestamp) (Data)	SQLite	C/I
A-05	Sharing grants and revocation state (Data)	SQLite	C/I
A-06	SHA-256 digest per evidence file (Data)	SQLite	I
A-07	Audit event records (Data)	SQLite / protected logs	C/I
A-08	Relational database (Component / data store)	SQLite file	C/I/A
A-09	Private object storage directory	Docker volume or private local	C/I/A

Asset ID	Asset and category	Location	CIA
	(Component / data store)	directory	
A-10	Web UI, API and authentication processes (Process / component)	FastAPI + Jinja2	C/I/A
A-11	Native metadata helper and invocation boundary (Component / process)	C executable called by server	I/A/C
A-12	Secrets and runtime configuration (Data / component)	Environment/config, never committed	C/I
A-13	Runtime compute and container (Component)	Docker/local host	A/I
A-14	Source code, dependencies and build workflow (Process / component)	GitHub repository / Actions	I/A
A-15	Web browser and signed-in user (External entity)	Investigator / collaborator endpoint	C/I
A-16	GitHub, Jira and MS Teams (External systems)	Collaboration and submission	I/A

4. Protection-needs register with CIA mappings

P0 = 7-day mandatory product/process baseline. P1 = deployment hardening and documented residual risk. This priority is not a CVSS score. C=Confidentiality, I=Integrity, A=Availability.

ID	Protection need / asset IDs	CIA	Priority
PNE-001	Only the owner and currently authorized collaborators may retrieve each evidence object. A-03/A-04/A-05	C,I	P0
PNE-002	Only the evidence owner may grant access to a named existing user. A-05/A-04	C,I	P0
PNE-003	Revoked collaborators must lose access at the next request. A-05/A-03	C,I	P0
PNE-004	Non-owners must not delete or alter evidence objects. A-03/A-04/A-05	I,A	P0
PNE-005	Sensitive operations must require an authenticated user. A-01/A-02/A-10	C,I	P0
PNE-006	Passwords must not be exposed in source, logs or stored as plaintext. A-01/A-12	C	P0
PNE-007	User sessions must resist predictable or cross-site misuse. A-02/A-15	C,I	P0
PNE-008	Cross-site pages must not silently perform sensitive state changes. A-02/A-05/A-10	I	P0
PNE-009	Sensitive pages must not be operable when embedded by an untrusted site. A-10/A-15	I	P0
PNE-010	Evidence files must not be publicly available through static web paths.	C	P0

ID	Protection need / asset IDs	CIA	Priority
	A-03/A-09/A-10		
PNE-011	External identifiers must not reveal paths or grant access by themselves. A-04/A-09	C	P0
PNE-012	Large uploads must not exhaust service capacity. A-03/A-09/A-13	A	P0
PNE-013	Untrusted metadata must not corrupt native memory. A-11/A-13	I,A	P0
PNE-014	User-supplied values must not become shell commands. A-11/A-13	C,I,A	P0
PNE-015	Untrusted filenames and paths must not escape private storage. A-03/A-04/A-09	C,I	P0
PNE-016	Evidence bytes must have a verifiable integrity reference. A-03/A-06	I	P0
PNE-017	Security-relevant evidence actions must be accountable. A-07/A-04	I	P0
PNE-018	Audit and error messages must not disclose secrets or evidence contents. A-07/A-12/A-10	C	P0
PNE-019	Database requests must not permit SQL manipulation by user inputs. A-08/A-10	C,I	P0
PNE-020	Invalid file metadata must fail closed without crashing normal workflows. A-04/A-11/A-13	I,A	P0
PNE-021	Deployment and build secrets must remain private and separately configurable. A-12/A-14	C,I	P0
PNE-022	High/critical findings must block the secure delivery workflow. A-14/A-10	I	P0
PNE-023	Security changes must be reviewed and traceable to the need they address. A-14/A-16	I	P0
PNE-024	Service failures must be detectable and startup reproducible. A-08/A-09/A-13	A	P0
PNE-025	Application runtime should minimize privileges. A-09/A-13	C,I,A	P1
PNE-026	Remote deployment should protect session and evidence traffic in transit. A-02/A-03/A-15	C,I	P1
PNE-027	Evidence and configuration should be recoverable after storage failures. A-03/A-08/A-09	A,I	P1

ID	Protection need / asset IDs	CIA	Priority
PNE-028	Authentication attempts should be resistant to automated guessing. A-01/A-10	C,A	P1
PNE-029	Evidence retention and deletion must follow an explicit policy. A-03/A-07/A-09	C,I	P1
PNE-030	Audit records should become tamper-evident for real investigations. A-07	I	P1

Coverage: 30 distinct needs (24 P0; 6 P1); CIA associations C=17, I=23, A=9. A need may address more than one pillar; none is unmapped.

5. Derived security requirements and measurable acceptance

Every PNE maps one-to-one to a “shall” statement and a numbered planned verification. T-xxx labels are test plans, not actual passed test results.

SR-001 / PNE-001 · P0 · CIA C,I

Shall: For every list/download route, server-side authorization shall evaluate the signed-in principal against that specific evidence ID and current share grants.

Acceptance: Two users: owner and grantee succeed; a third authenticated user and anonymous request receive 403 or non-disclosing 404; enumeration exposes no file content.

Planned T-001: Authorization integration test with 3 accounts + negative HTTP evidence.

SR-002 / PNE-002 · P0 · CIA C,I

Shall: Share endpoint shall require owner permission and a validated target account; reject self/invalid grants without exposing evidence.

Acceptance: Authorized grant succeeds; non-owner and unknown target cannot create grants; database remains unchanged on rejected attempts.

Planned T-002: Owner/non-owner grant tests + DB check.

SR-003 / PNE-003 · P0 · CIA C,I

Shall: Revocation shall update server-side grant state and every later download shall recheck current permissions.

Acceptance: After revocation, previously authorized collaborator receives 403/404; owner still succeeds.

Planned T-003: Grant → download → revoke → denied regression test.

SR-004 / PNE-004 · P0 · CIA I,A

Shall: Delete operation shall be owner-only; denied attempts shall not remove metadata, grants, or bytes.

Acceptance: Unauthorized delete rejected and original owner can still download the same file and digest.

Planned T-004: Two-account delete integration test.

SR-005 / PNE-005 · P0 · CIA C,I

Shall: Upload, list, download, share, revoke, delete and audit views shall enforce authenticated session checks.

Acceptance: Each protected endpoint rejects unauthenticated requests; authenticated owner workflows succeed.

Planned T-005: Authentication route matrix test.

SR-006 / PNE-006 · P0 · CIA C

Shall: Use vetted salted password hashing; never persist plaintext; prevent secrets from being printed.

Acceptance: Database password hash differs from entered password, login verifies it, no source code contains seeded plaintext credentials.

Planned T-006: Credential storage test + source inspection.

SR-007 / PNE-007 · P0 · CIA C,I

Shall: Use signed/unpredictable session state, HttpOnly and SameSite cookies, logout invalidation and appropriate expiry; Secure flag under HTTPS.

Acceptance: Logout prevents reuse; cookie attributes are visible; altered tokens are rejected.

Planned T-007: Cookie/header inspection and session lifecycle tests.

SR-008 / PNE-008 · P0 · CIA I

Shall: All authenticated browser state-changing forms shall require session-bound anti-CSRF token verification plus SameSite cookies.

Acceptance: Missing/wrong token rejected (403); correct token accepted; GET has no state-changing side effect.

Planned T-008: CSRF negative/positive test and controlled forged-form demo.

SR-009 / PNE-009 · P0 · CIA I

Shall: Authenticated pages shall emit CSP frame-ancestors 'none' and X-Frame-Options DENY.

Acceptance: Browser refuses to render secure page within cross-origin iframe; secure response headers contain the policy.

Planned T-009: Browser iframe demo + response header test.

SR-010 / PNE-010 · P0 · CIA C

Shall: Store evidence outside static root; access only via authorized server download route.

Acceptance: A guessed direct path cannot retrieve bytes; authorized API download succeeds.

Planned T-010: HTTP direct-path negative test + storage inspection.

SR-011 / PNE-011 · P0 · CIA C

Shall: Generate opaque evidence IDs and server-controlled storage names; never use client filenames as filesystem path components.

Acceptance: Uploads receive non-sequential random-looking IDs; path-like filenames do not traverse storage.

Planned T-011: Upload metadata and path traversal tests.

SR-012 / PNE-012 · P0 · CIA A

Shall: Reject oversized uploads with a configured maximum and bounded streaming/storage; clean up failed writes.

Acceptance: Configured over-limit upload rejected, not written to disk; subsequent normal request still succeeds.

Planned T-012: Boundary-size integration test and disk inspection.

SR-013 / PNE-013 • P0 • CIA I,A

Shall: Bound and validate native helper input lengths; use bounded memory operations; compile and test helper with AddressSanitizer.

Acceptance: Overlong input terminates safely with non-zero validation error; ASAN reports no overflow for fixed parser.

Planned T-013: Controlled legacy/fixed C harness + ASAN output.

SR-014 / PNE-014 • P0 • CIA C,I,A

Shall: Invoke the fixed native helper through argument arrays with shell disabled; validate input and set timeout.

Acceptance: Shell metacharacter input is treated as data or rejected; marker file/extra command never executes in secure version.

Planned T-014: Controlled legacy/fixed command invocation test.

SR-015 / PNE-015 • P0 • CIA C,I

Shall: Normalize and validate display metadata; use server-generated object storage paths, never client-supplied path segments.

Acceptance: Traversal patterns do not create or read files outside the configured private store.

Planned T-015: Traversal negative tests + filesystem assertions.

SR-016 / PNE-016 • P0 • CIA I

Shall: Compute SHA-256 on upload, store digest, and recompute/compare before authorized download or verification.

Acceptance: Original bytes match the stored digest; a deliberately modified test file is flagged as mismatched.

Planned T-016: Hash correctness and tamper-detection tests.

SR-017 / PNE-017 • P0 • CIA I

Shall: Record actor, event, evidence ID, outcome and UTC timestamp for upload/share/revoke/download/delete/failed authorization without recording file contents.

Acceptance: Each required event generates a timestamped record tied to actor and object; failures are recorded without file bytes.

Planned T-017: Audit event integration test and record screenshot.

SR-018 / PNE-018 • P0 • CIA C

Shall: Do not log passwords, session tokens, full file bodies, or secret configuration; use generic client errors.

Acceptance: Known secret/test content strings are absent from generated audit/error logs; 500 response does not show stack trace.

Planned T-018: Log redaction and safe-error tests.

SR-019 / PNE-019 • P0 • CIA C,I

Shall: Use parameterized DB operations and validated input; avoid dynamic SQL composition from request values.

Acceptance: SQL metacharacter username/filename does not change query scope, corrupt data, or authenticate falsely.

Planned T-019: DB query tests / static code review.

SR-020 / PNE-020 • P0 • CIA I,A

Shall: Validate length, encoding and allowed metadata at the web/native boundary; apply subprocess timeout and nonzero error handling.

Acceptance: Empty/overlong/invalid input rejected with controlled HTTP error; health endpoint stays reachable.

Planned T-020: Boundary, malformed-input and timeout tests.

SR-021 / PNE-021 • P0 • CIA C,I

Shall: Read secrets from environment/secret store; ignore .env and avoid real tokens in repo, images, CI logs and screenshots.

Acceptance: Repository secret scan has no real secret; app refuses unsafe missing production secret; local .env is ignored.

Planned T-021: Git ignore inspection + secret scanning.

SR-022 / PNE-022 • P0 • CIA I

Shall: Run tests, SAST and DAST evidence workflow; enforce a nonzero security stage result for verified high/critical findings.

Acceptance: Passing clean run is green; synthetic/known high finding in a controlled test makes required CI check fail.

Planned T-022: GitHub Actions/SAST/DAST artifacts, passing and failing screenshots.

SR-023 / PNE-023 • P0 • CIA I

Shall: Protect main; merge via PR with one peer approval; name PNE-ID in issue/PR and link later threat, fix, test records.

Acceptance: Main denies direct push; sample PR has reviewer approval and linked issue/test; actual issue keys saved after creation.

Planned T-023: GitHub settings screenshot + real PR screenshot.

SR-024 / PNE-024 • P0 • CIA A

Shall: Provide health endpoint, repeatable Docker Compose configuration, and clear restart/run instructions.

Acceptance: Container starts from documented commands and /health responds; restart returns service to healthy state.

Planned T-024: Docker Compose logs + health verification.

SR-025 / PNE-025 • P1 • CIA C,I,A

Shall: Run container process as non-root with least required filesystem permissions and avoid privileged mounting.

Acceptance: Inspection shows non-root UID and private writable directory only where required.

Planned T-025: Container inspection test.

SR-026 / PNE-026 • P1 • CIA C,I

Shall: For any internet-facing environment, terminate TLS and set Secure cookies; local HTTP is lab-only and must not be called production-ready.

Acceptance: HTTPS request succeeds; HTTP redirects/rejected and browser cookie carries Secure in deployed environment.

Planned T-026: Deployment configuration and TLS inspection.

SR-027 / PNE-027 · P1 · CIA A,I

Shall: Define encrypted backup, restore and integrity-check procedure for DB and file store; test before production use.

Acceptance: Restored dummy evidence metadata and bytes match recorded digest after a rehearsal.

Planned T-027: Documented restore drill (future).

SR-028 / PNE-028 · P1 · CIA C,A

Shall: Introduce per-account/IP login throttling and monitored failure events before broader exposure.

Acceptance: Repeated failed attempts trigger bounded rejection without blocking unrelated accounts.

Planned T-028: Rate-limit test (future).

SR-029 / PNE-029 · P1 · CIA C,I

Shall: Agree retention limits and deletion semantics; prevent unauthorized purge and document backups not necessarily erased by live deletion.

Acceptance: Policy defines retention and delete effect on primary/backup copy; sample deletion verified.

Planned T-029: Policy review + cleanup test (future).

SR-030 / PNE-030 · P1 · CIA I

Shall: For production, forward audit logs to protected append-only/tamper-evident store; a mutable local SQLite audit table is not tamper-proof.

Acceptance: Attempted modification detectable via protected archive/integrity chain; evidence of independent storage.

Planned T-030: Integrity chain test (future).

6. Five mandatory vulnerability mapping

Class / CWE	PNE IDs	Planned proof
CWE-120 Buffer Overflow	PNE-013, PNE-020	Legacy and fixed C helper + ASAN and input-boundary test
CWE-78 Command Injection	PNE-014, PNE-020	Legacy shell invocation vs fixed argv invocation + negative regression
CWE-639 IDOR	PNE-001–004	3-account unauthorized object read/share/revoke/delete checks
CWE-352 CSRF	PNE-008	Missing/invalid/valid token test + controlled demo
CWE-1021 Clickjacking	PNE-009	Legacy framed page, fixed browser block + CSP/XFO headers

7. Traceability and work management

Required chain: PNE-xxx → SR-xxx → TH-xxx (Phase 3 STRIDE threat) → actual Jira issue → real fix PR/commit → actual test run/evidence T-xxx. The exported PNE_Traceability_Register.csv leaves Threat ID, Jira issue, PR, and test-run cells empty until those events actually occur. JIRA_Backlog_Seed.csv includes five suggested epics and one story per need; Jira field mapping must be verified in the actual workspace.

Repository: SecureApp-Sprint-<TeamName>, real protected main, feature/fix PRs and peer review. Project management: live Jira board with To Do / In Progress / Done during the real sprint. These are required activities, not completed claims.

8. Limits, residual risks and review actions

- Instructor uniqueness/approval must be confirmed separately; selecting the theme internally is not instructor approval.
- C metadata parser must run in actual upload flow; the legacy vulnerability demo must stay isolated from the secure build.
- SHA-256 supports tamper detection on re-verification, but does not establish authorship or make the storage immutable.
- SQLite application-level audit entries can be edited by a privileged operator; tamper-evident audit is a P1 production follow-up.
- Local HTTP and local storage are lab configuration, not an assertion of production compliance or deployment readiness.
- Team must confirm file-size limit, file-type policy, authorization roles, retention policy and real sprint date before implementation.

9. Review and phase-gate checklist

☐ Team reads and validates all 30 proposed PNEs and any P1 risk acceptances.

☐ Actual team/member/date and real instructor approval status recorded.

☐ Asset inventory covers all four asset classes; all 30 need rows have CIA and measurable acceptance.

☐ Jira board and GitHub repository created during actual sprint; real screenshots saved.

☐ Phase 3 will create context/Level-1 DFD, STRIDE threats, at least two Attack Trees, CVSS vectors and linked risk register.

10. References / origin

CYC386 Fall 2026 Midterm Lab Exam brief (user-supplied), Sections 2, 4–7, particularly 6.2. CaseVault Phase 1 Architecture Blueprint (locked design direction; instructor approval is pending unless independently evidenced).